

Designing a Secured Multi-Zone Enterprise Network

A Hands-On GNS3 Lab: FortiGate, VLAN Segmentation, Routing, DHCP and Penetration Testing



Author: Marouane Aabirrouche

Program: Infrastructure Digitale – option Réseaux et Systèmes (OFPPT)

Tools: GNS3, FortiGate 7.0.9, Cisco IOU, Kali Linux

July 2026

Contents

1	Introduction	2
2	Objectives	2
3	Network Architecture	2
3.1	IP Addressing Plan	3
3.2	Trust Model	3
4	Core Routing and Switching (IOU2)	4
4.1	Uplink to the Firewall	4
4.2	Trunk Ports Toward Access Switches	4
4.3	Gateway Interfaces and DHCP	4
4.4	Access Control Between Zones	5
5	Access-Layer Hardening: Port Security	6
6	Perimeter Firewall: FortiGate Configuration	6
6.1	Interfaces and Routing	6
6.2	NAT and Internet Access	7
6.3	Anomaly-Based DoS and Scan Protection	8
6.4	Rate Limiting	9
7	Security Validation with Kali Linux	9
7.1	Placement Rationale	10
7.2	Tests Performed	10
7.3	Interpreting Results	11
8	Verification Summary	11
9	Challenges and Lessons Learned	11
10	Conclusion	12

1 Introduction

Network segmentation and perimeter security are foundational skills in system and network administration, yet they are difficult to practice without access to enterprise-grade hardware. This project was built to close that gap: a fully simulated, multi-zone enterprise network inside **GNS3**, combining a **FortiGate 7.0.9** firewall, layer-2/layer-3 Cisco IOU devices, DHCP services, VLAN-based segmentation, access control lists, port security, and a **Kali Linux** attacker machine used to validate that the defenses actually work.

A note on timing: the lab itself was built and tested some time ago and then left unfinished as a report – the topology was working, the configurations were saved, but the write-up never got done. This document is that write-up, finally completed, reconstructed from the saved configurations, screenshots, and notes from the original build.

The goal was not just to make the network “function”, but to reproduce the kind of design decisions a real network administrator has to make: where to draw trust boundaries, which zones should be allowed to talk to each other, how to prevent a compromised or malicious host from pivoting across the network, and how to verify security controls empirically rather than assuming they work.

Why this matters: most students learn firewall theory or VLAN theory in isolation. This lab forces both to interact – a misconfigured ACL, a missing static route, or a licensing limitation on the firewall each broke connectivity in a different, realistic way, and each had to be diagnosed methodically.

2 Objectives

- Design a network with clearly separated trust zones (Management, Sales, IT, DMZ).
- Implement VLAN segmentation using dot1Q trunking between a core router and access-layer switches.
- Centralize DHCP service delivery for all zones from a single core device.
- Configure inter-VLAN routing with *selective* zone communication rather than full mesh connectivity.
- Deploy a FortiGate firewall as the single point of egress, with NAT, static routing, and anomaly-based DoS protection.
- Harden access-layer switch ports with port security (sticky MAC, violation actions, BPDU guard).
- Validate the entire design using an actual attacker machine (Kali Linux) running reconnaissance and scanning tools.

3 Network Architecture

The topology consists of a FortiGate firewall sitting between the simulated Internet (NAT1 cloud) and an internal core router (IOU2), which distributes traffic to four access-layer switches, each representing an isolated organizational zone.

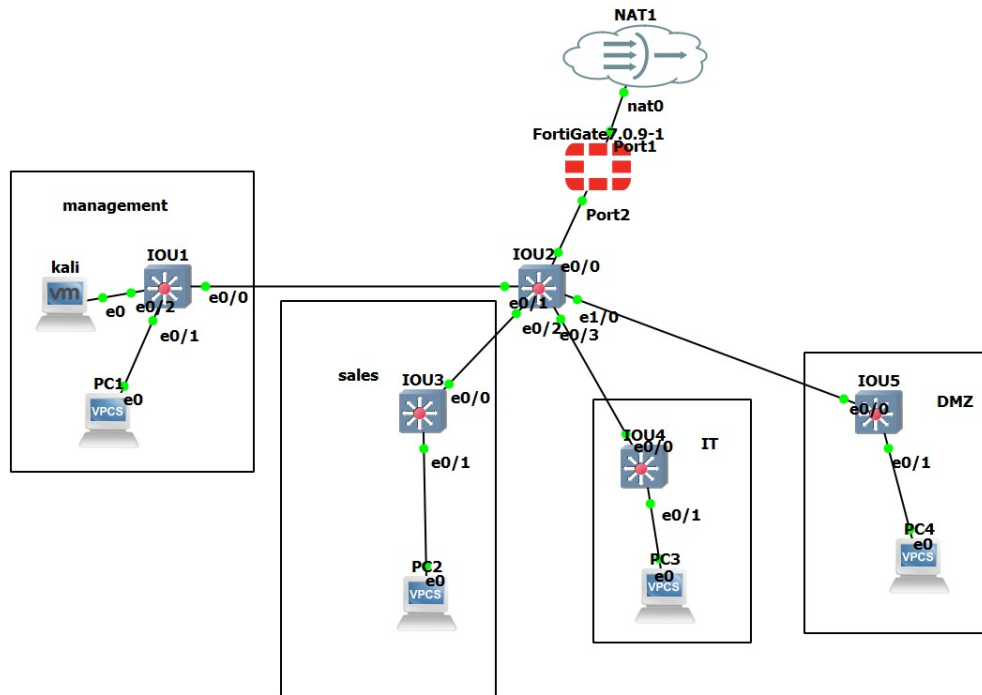


Figure 1: Final GNS3 topology: FortiGate perimeter firewall, IOU2 core router, four VLAN zones (Management, Sales, IT, DMZ), and a Kali Linux attacker host attached to the Management zone for security testing.

3.1 IP Addressing Plan

VLAN	Zone	Subnet	Gateway (IOU2)	Devices
10	Management	10.10.10.0/24	10.10.10.1	IOU1, PC1, Kali
20	Sales	10.10.20.0/24	10.10.20.1	IOU3, PC2
30	IT	10.10.30.0/24	10.10.30.1	IOU4, PC3
40	DMZ	10.10.40.0/24	10.10.40.1	IOU5, PC4
–	Core uplink	10.10.0.0/30	10.10.0.2 (IOU2) ↔ 10.10.0.1 (FortiGate)	–

3.2 Trust Model

The design follows a deliberate *least-privilege* model rather than a flat, fully-routed network:

- **Management ↔ IT:** explicitly permitted, since IT staff regularly need to reach management systems and vice versa.
- **Sales:** can reach the Internet but is blocked from every other internal zone.
- **DMZ:** fully isolated from all internal zones. A DMZ host is assumed public-facing and therefore the highest-risk segment; if compromised, it must not be able to pivot inward.
- **All zones:** pass through the FortiGate for Internet egress, where NAT and anomaly-based protections are enforced centrally.

4 Core Routing and Switching (IOU2)

IOU2 acts as the single core device for the whole network. Because the available IOU image was a router image rather than a dedicated L2/L3 switch image, VLAN interconnection was implemented using **802.1Q trunking and dot1Q subinterfaces / SVIs** instead of a native VLAN database – a good illustration of adapting a design to the constraints of the equipment actually available, which is a very common real-world situation.

4.1 Uplink to the Firewall

A dedicated point-to-point /30 link connects IOU2 to the FortiGate, keeping the firewall as the sole gateway to the outside world.

```
interface Ethernet1/0
description UPLINK_TO_FORTIGATE
no switchport
ip address 10.10.0.2 255.255.255.252
no shutdown

ip route 0.0.0.0 0.0.0.0 10.10.0.1
```

Listing 1: Uplink interface toward FortiGate

4.2 Trunk Ports Toward Access Switches

Each downstream switch receives a dedicated trunk carrying only the VLAN that belongs to its zone – deliberately restrictive rather than allowing all VLANs on every trunk.

```
interface Ethernet0/1
description TRUNK_TO_IOU1_MGMT
switchport trunk encapsulation dot1q
switchport mode trunk
switchport trunk allowed vlan 10
```

Listing 2: Example trunk configuration (Management zone)

The same pattern was repeated for Sales (VLAN 20), IT (VLAN 30), and DMZ (VLAN 40), each restricted to its own VLAN only.

4.3 Gateway Interfaces and DHCP

Each VLAN gets a routed gateway interface on IOU2, and a dedicated DHCP pool serves that subnet automatically, with the first ten addresses reserved for static assignments.

```
interface Vlan10
description MANAGEMENT
ip address 10.10.10.1 255.255.255.0
no shutdown

ip dhcp excluded-address 10.10.10.1 10.10.10.10
ip dhcp pool MGMT
network 10.10.10.0 255.255.255.0
default-router 10.10.10.1
dns-server 8.8.8.8
lease 1
```

Listing 3: VLAN gateway and DHCP pool

The same block was repeated for the Sales, IT, and DMZ pools with their respective subnets.

```

10.10.20.11      0100.5079.6668.01      Jul 15 2026 02:26 PM      Automatic
IOU2-CORE#show ip dhcp binding
Bindings from all pools not associated with VRF:
IP address      Client-ID/      Lease expiration      Type
                Hardware address/
                User name
10.10.10.11      0100.0c29.35e3.42      Jul 15 2026 02:09 PM      Automatic
10.10.10.12      0100.5079.6668.00      Jul 15 2026 02:25 PM      Automatic
10.10.20.11      0100.5079.6668.01      Jul 15 2026 02:26 PM      Automatic
10.10.30.11      0100.5079.6668.02      Jul 15 2026 02:27 PM      Automatic
10.10.40.11      0100.5079.6668.03      Jul 15 2026 02:27 PM      Automatic
IOU2-CORE#

```

Figure 2: DHCP bindings on IOU2 confirming that each VLAN's end devices received a lease from the correct pool.

4.4 Access Control Between Zones

Rather than isolating everything or allowing everything, standard extended ACLs enforce the trust model described in Section 3.2. The *deny* statements are placed before the final *permit*, since Cisco ACLs process top-down and stop at first match.

```

ip access-list extended SALES_OUT
deny ip 10.10.20.0 0.0.0.255 10.10.10.0 0.0.0.255
deny ip 10.10.20.0 0.0.0.255 10.10.30.0 0.0.0.255
deny ip 10.10.20.0 0.0.0.255 10.10.40.0 0.0.0.255
permit ip any any

interface vlan20
ip access-group SALES_OUT in

```

Listing 4: Sales zone isolation – Internet allowed, internal zones denied

```

ip access-list extended DMZ_OUT
deny ip 10.10.40.0 0.0.0.255 10.10.10.0 0.0.0.255
deny ip 10.10.40.0 0.0.0.255 10.10.20.0 0.0.0.255
deny ip 10.10.40.0 0.0.0.255 10.10.30.0 0.0.0.255
permit ip any any

interface vlan40
ip access-group DMZ_OUT in

```

Listing 5: DMZ isolation – no access to any internal zone

Management (VLAN 10) and IT (VLAN 30) intentionally received no restrictive ACL, allowing the two-way communication required by the design.

```

IOU2-CORE#
*Jul 14 14:23:23.701: %SYS-5-CONFIG_I: Configured from console by console
IOU2-CORE#show ip route
Codes: L - local, C - connected, S - static, R - RIP, M - mobile, B - BGP
        D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
        N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
        E1 - OSPF external type 1, E2 - OSPF external type 2
        i - IS-IS, su - IS-IS summary, L1 - IS-IS level-1, L2 - IS-IS level-2
        ia - IS-IS inter area, * - candidate default, U - per-user static route
        o - ODR, P - periodic downloaded static route, H - NHRP, l - LISP
        + - replicated route, % - next hop override

Gateway of last resort is 10.10.0.1 to network 0.0.0.0

S*   0.0.0.0/0 [1/0] via 10.10.0.1
      10.0.0.0/8 is variably subnetted, 10 subnets, 3 masks
C     10.10.0.0/30 is directly connected, Ethernet0/0
L     10.10.0.2/32 is directly connected, Ethernet0/0
C     10.10.10.0/24 is directly connected, Vlan10
L     10.10.10.1/32 is directly connected, Vlan10
C     10.10.20.0/24 is directly connected, Vlan20
L     10.10.20.1/32 is directly connected, Vlan20
C     10.10.30.0/24 is directly connected, Vlan30
L     10.10.30.1/32 is directly connected, Vlan30
C     10.10.40.0/24 is directly connected, Vlan40
L     10.10.40.1/32 is directly connected, Vlan40
IOU2-CORE#
IOU2-CORE#

```

Figure 3: IOU2 routing table showing all four VLAN interfaces and the default route toward the FortiGate.

5 Access-Layer Hardening: Port Security

Each access-layer switch (IOU1, IOU3, IOU4, IOU5) restricts its end-host-facing port to a single learned MAC address, stored persistently (“sticky”), with the port shutting down automatically if a second device is detected – a first line of defense against MAC spoofing or an unauthorized device being plugged into the network.

```

interface Ethernet0/1
description PC1
switchport mode access
switchport access vlan 10
switchport port-security maximum 1
switchport port-security violation shutdown
switchport port-security mac-address sticky
spanning-tree portfast
spanning-tree bpduguard enable

```

Listing 6: Port security on an access port (repeated per switch/zone)

On the core switch’s trunk ports, a higher threshold (3 MAC addresses: one for the switch itself, one for the connected end host, and one spare) was used with a *restrict* violation action, since a trunk naturally carries more than one MAC address.

6 Perimeter Firewall: FortiGate Configuration

The FortiGate 7.0.9 firewall is the single point of Internet egress and enforces network address translation, routing back to internal subnets, and anomaly-based scan/flood protection.

6.1 Interfaces and Routing

```

config system interface
edit port1

```

```
    set alias WAN
    set mode dhcp
    set allowaccess ping https http ssh
next
edit port2
    set alias LAN-UPLINK
    set ip 10.10.0.1 255.255.255.252
    set allowaccess ping
next
end
```

Listing 7: WAN and LAN-facing interfaces

Because FortiGate only knows directly-connected subnets by default, static routes were required for every internal VLAN, pointing back through IOU2:

```
config router static
edit 2
    set dst 10.10.10.0 255.255.255.0
    set gateway 10.10.0.2
    set device port2
next
edit 3
    set dst 10.10.20.0 255.255.255.0
    set gateway 10.10.0.2
    set device port2
next
edit 4
    set dst 10.10.30.0 255.255.255.0
    set gateway 10.10.0.2
    set device port2
next
edit 5
    set dst 10.10.40.0 255.255.255.0
    set gateway 10.10.0.2
    set device port2
next
end
```

Listing 8: Static routes for internal VLANs

6.2 NAT and Internet Access

```
config firewall policy
edit 1
    set name LAN-to-WAN
    set srcintf port2
    set dstintf port1
    set srcaddr all
    set dstaddr all
    set action accept
    set schedule always
    set service ALL
    set nat enable
next
end
```

Listing 9: LAN-to-WAN firewall policy with NAT enabled

```

FortiGate-VM64-KVM # show firewall policy
config firewall policy
edit 1
    set name "LAN-to-WAN"
    set uuid 3f1d9f2a-4c04-51f1-b5a6-d9ccd7a2f5fa
    set srcintf "port2"
    set dstintf "port1"
    set action accept
    set srcaddr "all"
    set dstaddr "all"
    set schedule "always"
    set service "ALL"
    set nat enable
next
edit 2
    set name "block-null-scan"
    set uuid 65689e9e-4c15-51f1-425b-404c0d85c89d
    set srcintf "port2"
    set dstintf "port1"
    set srcaddr "all"
    set dstaddr "all"
    set schedule "always"
    set service "ALL"
    set logtraffic all
next
end
FortiGate-VM64-KVM #
FortiGate-VM64-KVM #
FortiGate-VM64-KVM #

```

Figure 4: FortiGate firewall policy list, showing the LAN-to-WAN NAT rule enforcing controlled Internet egress.

6.3 Anomaly-Based DoS and Scan Protection

Instead of relying purely on the signature-based IPS engine (which was limited by an outdated evaluation signature database), a **DoS policy** using FortiGate's built-in anomaly detection was used to block TCP SYN floods, port scans, ICMP floods, and UDP floods – protection that does not depend on an up-to-date FortiGuard subscription.

```

config firewall DoS-policy
edit 1
    set name block-scans
    set interface port2
    set srcaddr all
    set dstaddr all
    set service ALL
    config anomaly
        edit tcp_syn_flood
            set status enable
            set action block
            set threshold 200
        next
        edit tcp_port_scan
            set status enable
            set action block
            set threshold 50
        next
        edit icmp_flood
            set status enable
            set action block
            set threshold 50
        next
        edit udp_flood
            set status enable
            set action block
            set threshold 100
        next
    end
next
end

```

Listing 10: DoS policy blocking scans and floods

```
FortiGate-VM64-KVM #
FortiGate-VM64-KVM # show firewall DoS-policy 1
config firewall DoS-policy
  edit 1
    set name "block-scans"
    set interface "port2"
    set srcaddr "all"
    set dstaddr "all"
    set service "ALL"
    config anomaly
      edit "tcp_syn_flood"
        set status enable
        set log enable
        set action block
        set threshold 200
      next
      edit "tcp_port_scan"
        set status enable
        set log enable
        set action block
        set threshold 50
      next
      edit "tcp_src_session"
        set threshold 5000
      next
      edit "tcp_dst_session"
        set threshold 5000
      next
      edit "udp_flood"
        set status enable
        set log enable
    end
  end
--More--
```

Figure 5: FortiGate DoS policy with anomaly detection enabled for SYN floods, port scans, ICMP floods, and UDP floods.

6.4 Rate Limiting

A traffic shaper caps bandwidth on the internal-facing interface, making automated scanning tools significantly slower and less effective even if a scan is not outright blocked.

```
config firewall shaper traffic-shaper
  edit limit-scans
    set maximum-bandwidth 1
    set guaranteed-bandwidth 1
    set per-policy enable
  next
end
```

Listing 11: Traffic shaper applied to internal traffic

7 Security Validation with Kali Linux

Configuring firewall rules is only half the exercise – the other half is proving they hold up against real tooling. A Kali Linux VM was imported directly into the GNS3 topology (rather than

run externally), avoiding routing complications and placing the attacker machine on the same simulated network as the rest of the lab.

7.1 Placement Rationale

Kali was attached to the Management zone switch (IOU1), simulating an insider or a compromised endpoint attempting to move laterally and probe other segments – arguably a more realistic and interesting threat model than an external scan, since perimeter firewalls are usually tuned for north-south traffic, while east-west (internal) traffic is often under-scrutinized.

7.2 Tests Performed

```
# Basic connectivity check
ping 10.10.10.1
ping 8.8.8.8

# SYN scan against an internal host - should trigger tcp_port_scan
nmap -sS 10.10.30.11

# Aggressive scan - triggers multiple DoS anomalies at once
nmap -A 10.10.30.11

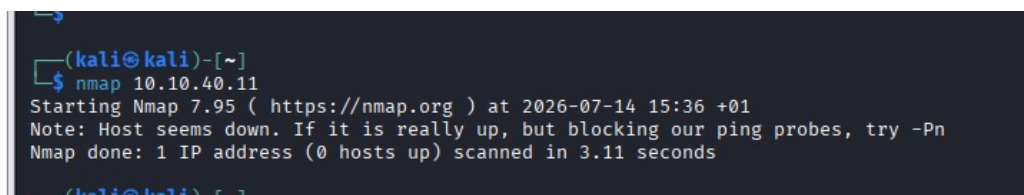
# Ping sweep across a subnet - triggers icmp_flood
nmap -sP 10.10.30.0/24

# Full port range scan - stress test for the DoS policy
nmap -p 1-65535 10.10.30.11
```

Listing 12: Reconnaissance and validation commands run from Kali

```
diagnose sniffer packet port2 "src 10.10.10.0/24" 4
execute log filter category 1
execute log display
```

Listing 13: Live packet inspection on FortiGate during the scan



```
(kali@kali)-[~]
$ nmap 10.10.40.11
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-14 15:36 +01
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.11 seconds
(kali@kali)-[~]
```

Figure 6: Kali Linux scanning an internal host from within the GNS3 topology.

```

PC1> ping 10.10.20.11
10.10.20.11 icmp_seq=1 timeout
10.10.20.11 icmp_seq=2 timeout
^C
PC1> ping 10.10.30.11
84 bytes from 10.10.30.11 icmp_seq=1 ttl=63 time=16.878 ms
84 bytes from 10.10.30.11 icmp_seq=2 ttl=63 time=3.326 ms
84 bytes from 10.10.30.11 icmp_seq=3 ttl=63 time=3.315 ms
^C
PC1>

```

Figure 7: Cross-zone ping test confirming that traffic between isolated zones is blocked as intended.

7.3 Interpreting Results

Observed result	Meaning
Scan takes far longer than expected, mostly filtered ports	Traffic shaper is throttling the connection successfully
Host seems down despite the host being up	DoS policy is dropping scan probes before they reach the target
Scan completes instantly, all ports filtered	Firewall/ACL is blocking traffic, though the DoS anomaly counters may not have been triggered
Scan completes normally with open ports visible	Control is not working as intended and needs review

8 Verification Summary

Test	Command	Expected Result
DHCP leases	show ip dhcp binding (IOU2)	4+ entries with MAC/IP pairs
Routing table	show ip route (IOU2)	All 4 VLAN interfaces + default route
Port security	show port-security	Secure ports, sticky MACs learned
Internet access	ping 8.8.8.8 from any PC	Success
IT ↔ Management	Cross-zone ping	Success (intentionally allowed)
Sales → Management/IT	Cross-zone ping	Blocked
DMZ → any internal zone	Cross-zone ping	Blocked
DoS policy status	show firewall DoS-policy 1	Active with all anomaly rules enabled

9 Challenges and Lessons Learned

- **Wrong IOU image type:** the initial IOU2 image was a router/TPGen image with no VLAN database support, requiring a redesign around dot1Q subinterfaces instead of native VLANs

- a reminder that lab constraints often force the same architectural adaptations seen in real deployments with legacy or limited hardware.
- **ACL ordering bug:** an early version of the Sales ACL placed the permit statement before the deny statements, silently allowing all traffic through. This reinforced the importance of understanding first-match ACL processing rather than assuming rules are evaluated as a complete set.
- **Case-sensitive ACL names:** applying an access-group with different capitalization than the ACL definition referenced a non-existent (empty) list, again allowing traffic that should have been blocked – a subtle but common source of “phantom” misconfigurations.
- **Port security math:** setting a maximum of 2 MAC addresses on a trunk port did not leave room for both the connected switch and its attached PC, which would have shut the port down as soon as a second device appeared. Understanding what actually counts toward the MAC limit on a trunk vs. an access port was an important distinction.
- **Firewall interface/route mismatch:** FortiGate had full Internet reachability but no way to route back to internal subnets until explicit static routes were added – a good illustration that a firewall’s own outbound connectivity says nothing about whether internal hosts behind it can actually reach the Internet.
- **Licensing limits on GNS3 firewall evaluation images:** signature-based IPS features required a valid, up-to-date FortiGuard database that was not available in the lab, so protection was implemented instead through anomaly-based DoS policies and traffic shaping – both fully functional without a live subscription.

10 Conclusion

This lab turned firewall and VLAN theory into a working, testable network. Every control implemented – from VLAN trunking to ACL zone isolation to FortiGate’s anomaly detection – was verified not just by checking configuration syntax, but by actively trying to defeat it with real reconnaissance tools from an attacker’s machine inside the same network. That loop of *configure* → *break* → *diagnose* → *fix* → *verify* is, in the end, the actual skill being practiced here, more so than any single command.